

WEBSITE CYBERSECURITY & EMERGENCY SHUTDOWN PROTOCOL

Architecture, Preventive Safeguards, Forensic Evidence Preservation, and Incident Response Playbook

Website Owner: Dr. Janardhan Mydam / JVA Medical Services

Target Audience: Practice Leadership & Engineering

Platform: Neonatology, Pediatrics & Education Portal

Protocol Status: Active & Verified in Codebase

Document Purpose: To provide Dr. Janardhan Mydam and administrative personnel with clear, definitive documentation explaining (1) the technical safeguards protecting the website from hacking, and (2) the exact operational protocol executed if an unauthorized breach, server attack, or account compromise is detected.

1. Proactive Security Safeguards (Preventing Attacks)

The platform has been engineered with defense-in-depth principles across authentication, database queries, and file operations to prevent security vulnerabilities:

Security Layer	Technical Safeguard Implemented	Threat Neutralized
Cryptographic Passwords	Passwords hashed using salted bcrypt with multiple rounds. Raw passwords are never written to disk or database.	Credential dumping and database dictionary attacks. Stored hashes cannot be reversed.
Session Tokens	Encrypted JWT tokens stored in HttpOnly, SameSite=Lax browser cookies.	Cross-Site Scripting (XSS) token theft. Malicious JavaScript cannot read session credentials.
SQL Injection Defense	All queries to Neon DB / VPS PostgreSQL use parameterized prepared statements (\$1, \$2, ...).	SQL Injection attacks. User inputs are strictly treated as data, never executable SQL commands.
File Upload Isolation	Uploads (lecture notes, assignments) are sanitized, timestamp-randomized, and restricted from executing code.	Remote Code Execution (RCE). Malicious script uploads (.php, .sh, .exe) cannot run.
Transport Encryption	Enforced HTTPS and database SSL transport encryption (sslmode=require).	Man-in-the-Middle (MitM) wire interception and data packet eavesdropping.
Minimal Data Footprint	Strictly educational records (name, email, mock exam scores). No credit cards or clinical health records stored.	High-liability data loss. Dramatically reduces exposure under privacy and medical regulations.

2. Emergency Shutdown: What Happens When Hackers Attack?

If unauthorized access, defacement, false medical guidance, ransomware, or server manipulation is detected, the **highest operational priority is taking the public website offline immediately** without deleting evidence.

Target Response Time: Under 60 Seconds. Public shutdown can be executed independently by the website owner or technical personnel without reliance on the external developer.

1

Immediate Emergency Killswitch Activation

The owner navigates to /admin/emergency and clicks "**ENGAGE EMERGENCY SHUTDOWN**" (or issues an API command using the private ADMIN_SECRET_KEY). This immediately puts the platform into offline mode.

2

Public Redirection to Maintenance Mode

Within seconds, all public pages, registration forms, student logins, and API routes are cut off from visitors. The public sees only the pre-approved professional notice:

"This website is temporarily unavailable while maintenance is being performed."

3**Forensic Evidence Preservation (Do NOT Delete Systems)**

Attacked systems must not be deleted or reformatted immediately. The platform automatically preserves server access logs, administrator login history, modified timestamps, and IP addresses in the `audit_logs` table. One-click CSV export enables immediate backup for legal and technical review.

4**Comprehensive Account & Credential Rotation**

All administrative credentials, domain/hosting access, database strings, and API secrets are rotated to lock out the adversary completely (see Step 3 below).

5**Vulnerability Investigation & Safe Restoration**

Technical personnel investigate how unauthorized access occurred, patch the vulnerability, verify no backdoor remains, and restore clean public access with owner confirmation.

3. Credential & Server Compromise Action Plan

If an administrative account or server key is suspected of being compromised, execute the following credential rotation order:

Asset	Immediate Action Required	Impact
Domain & DNS (Cloudflare/Registrar)	Change registrar password and verify Multi-Factor Authentication (MFA/2FA). Inspect DNS records for unauthorized redirects.	Prevents attackers from redirecting visitors to malicious phishing servers.
JWT Session Secret (JWT_SECRET)	Change the secret key in .env.local.	Instantly invalidates all active sessions. Hackers holding stolen cookies are immediately logged out.
Database Credentials (DATABASE_URL)	Reset Neon DB / VPS PostgreSQL user password and update connection string.	Terminates any rogue direct connections to the database layer.
Email Service (RESEND_API_KEY)	Revoke current API key in Resend dashboard; generate a new key and update environment variables.	Prevents attackers from broadcasting spam or phishing emails from the practice domain.
Admin Passwords	Execute bcrypt password reset in database for all administrative emails.	Prevents attackers from re-logging in with compromised passwords.

4. Legal, Privacy & Healthcare Compliance Escalation

Because Dr. Janardhan Mydam serves patients and students in the United States, strict adherence to US medical and privacy standards is maintained:

- ✓ **Educational Guidance Distinction:** Website consultations are clearly disclaimed as educational navigation and clinical mentorship, not telemedicine emergency services. This eliminates medical-licensure jurisdictional ambiguity across state lines.
- ✓ **Emergency Disclaimers:** Clinical guidance forms enforce bold disclaimers instructing patients to dial 911 or visit an emergency room in acute medical situations.
- ✓ **Breach Notification Assessment:** If personal data exposure is confirmed, counsel and hosting personnel are notified immediately to determine state and federal breach notification obligations.
- ✓ **Written Timeline Maintenance:** The owner maintains an audit log: *Discovery Time → Website Disabled → Parties Notified → Evidence Preserved → Credentials Rotated → Investigation → Restoration.*

5. Pre-Launch Owner Verification & Sign-Off

Per the website cybersecurity mandate, before public launch, the technical team has demonstrated that if the developer is unreachable, the owner can independently take the public website offline within minutes without deleting the database or evidence.

CYBERSECURITY & EMERGENCY SHUTDOWN PROTOCOL SIGN-OFF

By signing below, the developer confirms the emergency offline maintenance mode and forensic audit logging have been implemented and verified in the codebase. The website owner confirms receipt of access controls and operational training.

TECHNICAL DEVELOPER CONFIRMATION:

WEBSITE OWNER & MEDICAL DIRECTOR:

Rohith Reddy / Engineering Team

Date: September 9, 2026

Dr. Janardhan Mydam, MD, FAAP

JVA Medical Services · Date: _____